next.js / security tool responses

next.js 15.2.2 trusted an internal middleware header supplied by the client. repeating the middleware name made the server skip the check protecting the admin page. the two configurations show what changes when an independent session check sits in front of the same vulnerable app.

the configurations

configuration 1: crs pl2 + et-open ips + dlp block. crs 4.12.0 used inbound threshold 5 and outbound threshold 4. suricata ran inline through nfqueue. response and egress dlp were in block mode, with docker isolation and recorded wazuh telemetry.

configuration 2: the same controls plus an authorization gateway checking the protected root route and the synthetic session before forwarding.

dlp gateway

```
timestamp: "2026-10-16T01:29:19.442563+00:00"
request_id: "CVE-2025-29927-mode-a-20261016T012801Z-nextjs-exploit"
status: 200
cookie_present: false
authorization_present: false
verdict: "allow"
reason: "no_blocking_match"
response_bytes: 8835
```

case summary

request	configuration 1	configuration 2	meaning
no session, no exploit header	307	307	normal login check
invalid session	307	307	invalid session rejected
no session, forged header	200	307	gateway stopped the bypass
valid session, forged header	200	200	authorized access still worked

configuration 1 served 8,835 response bytes without a login cookie. configuration 2 returned a redirect with no admin response body. the archive includes a matching baseline for both tests.

configuration 1 / allowed

modsecurity

```
time_stamp: "Fri Oct 16 01:29:19 2026"
request.method: "GET"
request.uri: "/"
request.headers.Host: "waf:8080"
request.headers.x-middleware-subrequest:
   "middleware:middleware:middleware:middleware:middleware"
request.headers.X-Request-ID: "CVE-2025-29927-mode-a-20261016T012801Z-nextjs-exploit"
response.http_code: 200
producer.secrules_engine: "Enabled"
messages: []
```

the waf audit record contains the forged header and a 200 response, with an empty message list. the request was visible to the waf, but this transaction has no recorded crs rule match. no session rule in this layer decided whether the returned page belonged to the caller.

modsecurity

```
time_stamp: "Fri Oct 16 01:28:12 2026"
request.headers.Host: "127.0.0.1:8080"
response.http_code: 200
ruleId: "920350"
message: "Host header is a numeric IP address"
```

rule 920350 means the host header is a numeric ip address. this warning belongs to a different readiness request. the successful exploit used the host name waf:8080 and recorded no messages. a host-format warning is not evidence that crs recognized the authorization bypass.

layer	what was visible	why it passed
modsecurity crs	request and response	no matching rule on the exploit transaction
response dlp	200, no cookie, no content matches	content inspection did not enforce identity
next.js	forged middleware recursion header	vulnerable middleware check was skipped

configuration 2 / session check

wazuh

```
timestamp: "2026-10-16T01:35:18.904+0000"
rule.id: "110161"
rule.level: 6
rule.description: "SCL trusted policy denied protected-route access without a valid session"
data.request_id: "CVE-2025-29927-mode-b-20261016T013356Z-nextjs-exploit"
data.trusted_decision_source: "true"
data.route: "/"
data.session_state: "missing"
data.decision: "deny"
data.enforcement: "redirect"
```

lab rule 110161 reported a trusted denial for the protected root route. the session was missing, so the authorization gateway redirected the request before it reached next.js. wazuh received that decision; the gateway performed the prevention.

wazuh

```
timestamp: "2026-10-16T01:35:20.891+0000"
rule.id: "110160"
rule.level: 3
rule.description: "SCL trusted authorization decision"
data.request_id: "CVE-2025-29927-mode-b-20261016T013356Z-nextjs-valid-exploit"
data.session_state: "valid"
data.decision: "allow"
data.upstream_status: "200"
```

lab rule 110160 recorded the corresponding trusted allow decision for a valid session. the same exploit header remained present in that test and the response was 200. this shows that the improvement was independent session enforcement, not a blanket block of the header.

signal	recorded result	correct interpretation
110161 / level 6	missing session; deny; redirect	protected access was prevented by the gateway
110160 / level 3	valid session; allow	authorized traffic remained usable
response dlp	allow; status 307	dlp passed the gateway redirect; it did not cause it

ips and siem / what was visible

wazuh

```
timestamp: "2026-10-16T01:29:22.593+0000"
rule.id: "86601"
rule.level: 3
rule.description: "Suricata: Alert - SCL IPS positive-control header"
data.alert.signature_id: "1001001"
data.alert.signature: "SCL IPS positive-control header"
data.alert.action: "blocked"
```

sid 1001001 is the lab's positive-control header rule. it matched the deliberate probe and reported blocked. wazuh rule 86601 copied that suricata alert at level 3. this confirms a working alert path and one enforced drop rule, not coverage of every attack.

evidence	configuration 1	configuration 2
positive-control probe	sid 1001001 / blocked	sid 1001001 / blocked
cve-specific ips signature	none recorded in the selected run	none recorded in the selected run
request telemetry	http flow and gateway records	http flow, gateway and identity decisions
trusted route decision in wazuh	no authorization events in this stream	110161 denies and 110160 allows
exploit result without a session	admin html returned	redirected by independent gateway

why visible traffic was not enough

a flow log can show a request to the root route without proving whether the caller is allowed to open it. configuration 1 had no trusted authorization decision in this log stream. configuration 2 supplied that missing context and enforced it outside the vulnerable middleware.

the selected run records support a detection gap for this cve in the deployed signature set. they do not show that suricata or a waf could never detect a matching header rule. the same logs show successful blocking of their separate positive control.

what dlp recognized

these are separate synthetic classifier probes. they do not establish that this cve stole those test documents. their request ids identify the control traffic.

wazuh

```
timestamp: "2026-10-16T01:29:34.590+0000"
rule.id: "110101"
rule.level: 10
rule.description: "SCL DLP blocked classified data or destination"
data.request_id: "CVE-2025-29927-mode-a-20261016T012801Z-recognized_confidential"
data.verdict: "block"
data.reason: "request_content"
data.match_types: ["confidential_label", "synthetic_api_key", "tracked_document"]
data.bytes: "65"
```

lab rule 110101 reported the gateway's block. the reason was request content, so this was a classifier decision. the gateway enforced it; wazuh recorded it.

wazuh

```
timestamp: "2026-10-16T01:29:34.596+0000"
rule.id: "110120"
rule.level: 10
rule.description: "SCL isolated receiver recorded data movement"
data.request_id: "CVE-2025-29927-mode-a-20261016T012801Z-unrecognized_restricted"
data.component: "external-receiver"
data.bytes: "79"
```

sample	payload bytes	gateway	receiver
public control	25	201 / allowed	recorded
recognized confidential	65	403 / blocked	no receipt
unrecognized restricted	79	201 / allowed	recorded
base64 of recognized sample	56	201 / allowed	recorded

rule 110120 records receipt of data. it also fires for the public control, so its name alone does not prove theft. the unrecognized and base64 samples expose gaps in this classifier policy.

findings and fixes

control or rule	observed response	what it means here
crs pl2	no exploit message; 200	request visibility without an access-control decision
920350	numeric-host warning on another request	host formatting, not cve recognition
ips 1001001 / wazuh 86601	positive-control probe blocked and reported	one working drop path; no cve-specific alert recorded
authorization gateway / 110161	forged request denied with missing session	independent policy prevented this bypass
110101	recognized classifier sample blocked	content policy worked on its known marker
110120	unrecognized and base64 samples received	movement was visible; classification did not stop it

fix the application. upgrade to a supported, fully patched next.js release. reject or remove external x-middleware-subrequest headers at public ingress, and keep permission checks inside sensitive server operations. retain a verified session check outside middleware.

test the actual decisions. repeat no-session, invalid-session and valid-session requests with identical headers. keep signature probes separate from authorization tests. improve classifier coverage and transformed-content handling without treating content matches as identity checks.

references

next.js security advisory - middleware bypass and official workaround

owasp crs anomaly scoring - matches, scores and blocking are separate

suricata rule actions - alert and drop have different effects

wazuh suricata rules - 86601 processes suricata alert events